Contents

Volume 03 — Policy & Risk Management **1**
Lecture T15: Cybersecurity Policy — Part 01 1
Lecture T16: Cybersecurity Policy — Part 02 2
Lecture T17: Cybersecurity Policy — Part 03 4
Lecture T18: Cybersecurity and Privacy — Extended Discussion (live) 5
Lecture T19: Risk Management — Part 01 6
Lecture T20: Risk Management — Part 02 7
Lecture T21: Risk Management — Part 03 8

Volume 03 — Policy & Risk Management

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T15: Cybersecurity Policy — Part 01

Learning focus

- Treat policy as the **reference document** that planning and day-to-day security decisions go back to.
- Separate **norm**, **policy**, and **regulation** (law).
- See policy as something that can **enable** or **disable** an organization, and that **changes behavior** at country, firm, and individual levels.
- Apply the first formation rule: a policy must **never conflict with the law** and must **stand up in court**.
- Hold both sides of the trade-off the instructor keeps repeating: **protect** without blocking **progress**.

Key terms

Term	Meaning in this lecture
Policy	Binding reference document so the organization can meet objectives with fairness; not only for one person
Social norm	Unwritten expectation (dress for class); not court-enforceable
Regulation / law	Legally enforceable rule; someone can take you to court
Shredding / retention policy	How long documents are kept; must be specific enough to survive court
Due diligence (implementation)	Stating the rule is not enough; firewalls and admin must actually carry it out
Protect vs progress	Safety controls vs the organization's ability to work; policy has to balance both

Distinctions

- **Norm is not regulation.** Dressing for class is a norm; law is what a court can enforce.
- **Policy is not automatically law.** It becomes regulation only if it is legally enforceable.
- **A convenient policy is not a lawful policy.** Andersen's "till it is relevant" was a policy that conflicted with the law.
- **Framing ≠ implementation.** "Employees must not visit illegal sites" is weak in court if the firewall still lets them through.
- **Individual fault does not automatically clear the organization.** Without a policy and due care, the org is still in the argument.
- **More restriction is not automatically better policy.** A policy that blocks work will be violated.

Exam lines

- Policy is the reference that tells you cybersecurity is a priority and how people must behave; without it there is nothing to refer to in a crisis.
- Policy can enable (India IT) or disable (no document, or a document that makes work impossible).
- Quote-level balance: protect privacy **without inhibiting** digital technologies.
- First principle: **do not contradict the law**; use measurable retention rules, not "till relevant."
- For internet misuse: written policy **and** blocking/implementation; both employee and organization can be responsible.
- Behavior change is the point: well-framed policy invites compliance; fear-only or unusable policy produces violation or inefficient compliance.

Lecture T16: Cybersecurity Policy — Part 02

Learning focus

- Separate **policy, standards, procedures, and guidelines**.
- Use the three-level hierarchy the lecture treats as standard terminology: **EISP**, **ISSP**, **SysSP**.
- Treat policy as a **long-term master document**; put changing legal detail in standards/procedures.
- Explain **SETA** and why dissemination is a management duty.
- Map SysSP onto **management guidance** plus **technical specification** (ACL and configuration rules).
- Distinguish **firewall (prevention)** from **IDS (detection)**.

Key terms

Term	Meaning in this lecture
EISP	Enterprise Information Security (Program) Policy — top, strategy, scope, tone, roles
ISSP	Issue-Specific Information Security Policy — technology/issue level; can indemnify the organization
SysSP	System-Specific Information Security Policy — management guidance + technical specs
SETA	Security Education, Training and Awareness
Indemnify	Absolve of responsibility; ISSP is written so the **organization** is protected in typical IT abuse cases
ACL	Access control list: roles × resources × privileges × when/where/how
Firewall	Preventive control of traffic in and out
IDS	Intrusion detection — alarm, not prevention
Tone	Word choice in EISP ("critical" vs "due importance") that signals resource commitment

Distinctions

- **Policy ≠ procedure.** Policy is the long-term reference; firewall rules are procedures.
- **Do not rewrite EISP when a statutory clock changes.** "Comply with the law" stays; the hour-count lives in standards.
- **EISP is not ISSP.** Enterprise document talks mission and roles; ISSP talks email/cloud/WFH and monitoring.
- **Indemnifying the organization is not the same as indemnifying employees.** Medicine often indemnifies doctors; this ISSP discussion is about protecting the firm from employee misuse.
- **Stated policy without SysSP implementation fails in court.**
- **Firewall is not IDS.** One prevents; one detects.
- Job titles on the org chart (**Director–IT**) may be wrong even when the **EISP/ISSP/SysSP** concepts still apply.

Exam lines

- Hierarchy to memorize: **EISP → ISSP → SysSP**, with email as the stock example (facility → use rules → 5 GB config).
- SETA is how policy actually reaches people; this course is the **E**.
- ISSP is also a **legal** document (monitoring notice + indemnification).
- SysSP = guidance document + ACL + configuration (firewall/IDS).
- Policy is stable; standards move when regulation's details move.

Lecture T17: Cybersecurity Policy — Part 03

Learning focus

- Restate the article's claim: **spending on cyber defense does not guarantee** you will be shielded.
- Define **critical infrastructure** as the lecture's student group used it, and why coupling across sectors raises consequence.
- Contrast **cyber hygiene** with what a **determined attacker** can still do.
- Use Idaho National Laboratory's **CCE** and **CIE** as a policy-relevant alternative to "buy more tools."
- Carry forward the sentence the instructor underlines at the end: **any system connected to the internet is not secure.**

Key terms

Term	Meaning in this lecture
Internet insecurity	Article's frame: connected systems are not secure; "cybersecurity spend" is the wrong guarantee
Critical infrastructure	Energy, telecom, critical manufacturing, transport, water; now interdependent grids
Cyber hygiene	Routine scanning, patching, training, segmentation, password discipline — necessary, not sufficient
CCE	Consequence-Driven Cyber-Informed Engineering — start from worst consequence, then cut digital paths
CIE	Cyber-Informed Engineering — include cyber as a failure mode from conceptual design
Crown jewel	The function whose loss jeopardizes the whole operation
Air gap	Keep the redundant / critical path off the internet so backup is not hit with the primary

Distinctions

- The series title is **insecurity**, not security — that is the point.
- **More spend ≠ guaranteed protection.**
- **Hygiene ≠ survival against a dedicated attacker.**
- **CCE is not "abandon automation."** It is redundancy and less digital exposure for the crown jewel.
- **Do not air-gap the primary and then network the backup.**
- Cyber should be treated as an engineering **failure mode**, not an IT afterthought (firewall later).
- **Capability and vulnerability rise together** in digital transformation.

Exam lines

- Quote-level claim to remember: a system on the internet is **not secure**.
- Critical infrastructure is **coupled**; one failure can cascade.

- Hygiene (patches, training, segmentation) is the floor; INL's answer is **consequence-first** design and **reduced digital pathways**.
- CCE four steps and the crown-jewel language are the article's method.
- Next case (**Protecting the Cheddar**) is how this argument looks inside a factory.

Lecture T18: Cybersecurity and Privacy — Extended Discussion (live)

Learning focus

- Expand **BIA** as asked in chat: **Business Impact Analysis** (Week 4, contingency planning).
- Place **policy** between contingency planning and risk management: policy **guides** risk work.
- Restate policy as the instrument that makes **desired behavior** appear — national, organizational, individual.
- Keep the internet-insecurity claim in decision language: **what you connect and what you don't**, once you accept that connected systems are insecure.
- Know the Week 5 reading the instructor actually assigned (textbook chapter and the HBR article).

Key terms

Term	Meaning in this lecture
BIA	**Business Impact Analysis** — Week 4 contingency-planning assessment (full form as given in this live session)
Policy (behavior)	The document **and its implementation** that produce desired (including compliant) behavior
Levels of policy	Same intent at different abstraction: strategy/priorities down to firewall rules
Critical infrastructure	What must keep running for a country or a firm (health, energy, finance named)
Internet insecurity	Connected ⇒ insecure; policy is choosing what stays on the network

Distinctions

- **Content questions vs platform rules.** This session is for the former.
- **PG class ≠ UG textbook recitation.** Cases and HBR are mandatory advanced material, not decoration.
- **iPremier is not a topic change**; it is contingency planning in a real incident.
- **Policy on paper is not behavior change** unless communicated and implemented.
- **Disconnecting from the internet is not free** — you trade efficiency for a smaller attack surface.
- This course is **knowledge / concepts**, not CEH-style skill training.
- **BIA** in this Q&A is the **name** of the Week 4 analysis, not a new formula lecture.

Exam lines

- **BIA = Business Impact Analysis** (contingency planning, Week 4).
- Policy week sits **between** contingency and risk because policy is the reference that **guides** risk management.
- Desired security behavior does not "evolve" without policy that is **known and implemented**.
- Critical infrastructure must be **identified** before it can be prioritized; connected infrastructure is **insecure** by the article's observation.
- First professional question: **what is the policy?**

Lecture T19: Risk Management — Part 01

Learning focus

- Contrast **contingency planning** (reactive; unit = **business process**) with **risk management** (preventive; unit = **assets**).
- State risk management as **identifying, assessing, and reducing** risk — **not eliminating** it.
- Use Sun Tzu's pair **know the enemy / know yourself** as the frame for threats vs assets and preparedness.
- Explain **residual risk** as leftover risk after base safeguards, extra safeguards, and remaining vulnerabilities.
- Walk **risk identification**: six asset categories, tagging/database, classification, and **business-impact** valuation (not purchase price).

Key terms

Term	Meaning in this lecture
Risk management	Identify, assess, **reduce** risk to cyber assets (not eliminate)
Know yourself	Assets + current preparedness
Know the enemy	Threat intelligence (internal and external)
Attack	Threat that has exploited leftover vulnerability
Attack surface	Two-dimensional view: threats × assets (sometimes loosely called vector)
Residual risk	Leftover risk after base safeguards, extra safeguards, and remaining vulnerabilities
Loss frequency	Probability-side measure (introduced here; formula next lecture)
Loss magnitude	Impact-side measure; function of **business** value of the asset
Asset valuation	Weighted business-impact score, not invoice cost
Security clearance	Person's authorized access class

Distinctions

- **Contingency ≠ risk management.** Process unit vs asset unit; reactive vs preventive.
- **Reduce ≠ eliminate.** Internet-connected devices have no 100% guarantee. **Reduce** vs **mitigate** will be nuanced later.
- **Residual risk is what you actually manage**, because some protection already exists.
- **Attack surface is not "list of threats."** It is threats **with** assets.
- **Vector** implies **more than one dimension** — do not use the word emptily.
- **Asset value ≠ purchase cost.** SSL order channel at 100 is about stopping the business.
- **Unclassified ≠ sensitive-but-unclassified** in the military scheme they discussed.
- Risk management is **not** a five-year plan you finish.

Exam lines

- RM = identify, assess, reduce; object is **residual risk**.
- Know yourself (assets, preparedness) and know the enemy (threats).
- Six asset categories include **people and procedures**, not only hardware.
- Classify people and data; value assets with a **business-impact** instrument.
- Next lectures: threats, TVA worksheet, then the residual-risk **formula**.

Lecture T20: Risk Management — Part 02

Learning focus

- Identify and **classify** threats; treat **threat intelligence** as **external** data.
- Place **vulnerability on the threat–asset pair**, not on "the firm" in the abstract.
- Use the **TVA worksheet** (threat–vulnerability–asset) as the assessment instrument.
- Compute **loss frequency** and **loss magnitude**, then **residual risk**.
- Record the **in-video four-term formula**, the **worked example that dropped current controls**, and the **instructor's later correction** that removes the mitigated-controls term.

Key terms

Term	Meaning in this lecture
Threat intelligence	External, subscribed, dynamic scoring of threats
Espionage	Insider (or former insider) leaking against the organization/country
Technological obsolescence	A threat class: running critical work on un-updated platforms
Vulnerability	Gap **for a specific asset against a specific threat**
TVA worksheet	Spreadsheet of threats × assets with vulnerability in each cell
Loss frequency	P(attack) × P(success)

Term	Meaning in this lecture
Loss magnitude / exposure	Asset value × % lost in a successful attack
Measurement uncertainty	Worst-case add-on from estimate error
Residual risk	Leftover risk after you have combined LF, LM, (and originally current controls,) plus uncertainty

Distinctions

- **Asset valuation is internal; threat intelligence is external.**
- **Vulnerability is not a free-floating property of the company.** It is a **cell** in TVA.
- **Likelihood of attack ≠ likelihood of success.** Frequency uses **both**.
- **Exposure is not always 100%** of asset value.
- **LF × LM is not the whole residual-risk story** until you add **measurement uncertainty** (worst case).
- **Minus current controls** was taught, then **removed**: do not treat that subtraction as the working formula after the correction; controls are already inside success-probability / vulnerability if assessment is done in place.
- Quantitative is the textbook method; **qualitative is what many shops actually do** because the numbers are hard.

Exam lines

- TVA: threats on one axis, assets on the other, vulnerability in the cell; sort so the **diagonal** is hottest.
- LF = 0.1 × 0.5 = 0.05; LM = 50 × 0.8 = 40; product = 2; +25% uncertainty = **2.5**.
- Remember the **correction**: residual risk = **LF × LM + measurement uncertainty** (no mitigated-controls term).
- Next: what the organization **does** with those numbers (control).

Lecture T21: Risk Management — Part 03

Learning focus

- Apply the **internet-insecurity / CCE** argument to an industrial plant, not only to "IT."
- Reconstruct **Protecting the Cheddar** (Newhouse Cheese): ransomware, recipes, temperature control, $6 million already spent.
- Use the consultant's **four-step** plan as the same crown-jewel method as CCE.
- Hold the class debate: **full rollback vs in-between** (critical functions off the open digital path).
- Hear the instructor's stakes: **listeria / lives**, **ransomware-as-a-service**, **WannaCry / NotPetya**, and Industry 4.0 / IoT.

Key terms

Term	Meaning in this lecture
Protecting the Cheddar	HBS-style case: cheese manufacturer, ransomware, digitized process control
Thermization	Process Jack wants **completely offline**
Digital terrain	Hardware, software, network, human interaction, supply chain around a process
RaaS	Ransomware as a service — criminals buy the tool
Listeria	Food-safety catastrophe if temperature/composition controls are subverted
Least privilege / compartmentalization	Mixed-system argument: a breach should not see the whole plant
Sunk cost	Digitization money already spent; not a reason the consultant accepts to stay fully online

Distinctions

- **Paying $6 million for tools ≠ fewer breaches.** Same lesson as the HBR spend charts.
- **Jack is not selling the Stone Age.** He is selling **fewer digital pathways** to crown jewels.
- **Ransomware scare vs listeria:** in food ICS, **integrity of the process** can be a **life** issue, not only an IT issue.
- **Manual control ≠ automatically safer** — human error was why they automated.
- **NotPetya ≠ "pay and recover."** Payment may not restore the machines.
- Industry 4.0 gains and this class of risk **arrive together**.

Exam lines

- Cheddar storyline: pay **$49,999**, $6M already spent, recipes + temperature ICS, consultant maps terrain and pulls **critical** processes toward **offline / human backstop**.
- Four steps to memorize with CCE: crown jewel, digital terrain, likely path, mitigation options.
- Class/instructor landing zone: **in-between**, not total disconnect and not "business as usual online."
- Ransomware (including RaaS, WannaCry, NotPetya) is **high** in threat intelligence for industrial control; consequence can be **lives**, not only coins.
- Formal **risk-control menu** is deferred; **industry session** is next.
